



# AI 安全世界

白帽大会的议程地图与风险坐标

HackProve World 2026 白帽世界大会

中国澳门 MGM Macau

主题 01 讲义：00:00:00-00:06:45

基于本主题字幕、transcript 与用户允许的官方参考整理

# 目录

|                         |    |
|-------------------------|----|
| 摘要                      | 2  |
| 1 术语与阅读地图               | 2  |
| 1.1 开场词中的四个关键词          | 2  |
| 1.2 本讲义的阅读边界            | 3  |
| 2 会场语境：从会议厅到现场竞技场       | 3  |
| 2.1 地点本身传递的信号           | 3  |
| 2.2 大会主题：AI 与白帽的联合智能    | 4  |
| 3 白帽角色变化：速度扩大，判断更贵      | 4  |
| 3.1 AI 扩大了安全工作的半径       | 4  |
| 3.2 白帽价值从执行转向判断         | 5  |
| 4 议程地图：十个主题如何组成一条路线     | 5  |
| 4.1 从入口到深水区             | 5  |
| 4.2 议程索引表               | 5  |
| 5 风险坐标：读完整场会要盯住什么       | 6  |
| 5.1 五元坐标：资产、威胁、控制、证据、人员 | 6  |
| 5.2 对偶概念：能力与边界          | 7  |
| 6 如何读后续主题               | 7  |
| 6.1 先看问题类型，再看技术细节       | 7  |
| 6.2 把白帽问题写成检查清单         | 8  |
| 7 图像块                   | 8  |
| 8 总结                    | 10 |
| 官方参考                    | 10 |

# 摘要

开场还点名了 Google、Meta、Tencent、Trendero、Google Cyber、Huffman Cyber Security 等讲者或机构来源。这个名单提供了议程密度信号：后续内容横跨云平台、社交平台、企业安全团队、渗透测试公司和安全社区，AI 安全问题会在不同组织边界之间移动。读后续主题时，要把“谁拥有数据、谁拥有工具、谁承担响应责任”一起看。

HackProve World 2026 的开场把会场定位为 **AI security live arena**：一个把攻击性思维、真实世界防御、白帽判断力和多机构协同放在同一张桌面上的现场。主持人提到澳门、MGM Macau、“land of hackers”，随后把年度主题指向“Collective Intelligence: The Union of AI and White Hat”。这段开场并不承担单项技术教学，它承担坐标系搭建：今天的听众要用什么视角进入 AI 安全，后续十个主题之间如何相互定位，白帽在模型自动化时代为什么仍然是关键节点。

本讲义只覆盖主题 01 的大会语境和阅读路线。后续关于 AI 驱动防御、合规运营、CPU 漏洞、MCP、签名协议、微调数据攻击、模型工程、审计链路和分布式攻击实验的细节，将留给对应主题展开。这里先给读者一张地图：哪里是资产，哪里是威胁，哪里需要控制，哪里必须留下证据。

一句话定位

AI 安全在本大会中的含义，可以先理解为：围绕模型、数据、工具、部署环境与人机协作的风险识别、缓解、验证与复盘。它接续传统网络安全的资产保护逻辑，也加入模型行为、上下文污染、自动化攻击面和人机责任边界等新变量。

## 1 术语与阅读地图

### 1.1 开场词中的四个关键词

| 关键词                | 会场语境                        | 阅读提示                                      |
|--------------------|-----------------------------|-------------------------------------------|
| AI security        | 主持人把主会场称为 AI 安全的现场竞技场。      | 先看攻防关系，再看工程落地。模型只是一部分，数据、工具、权限、日志同样进入安全面。 |
| Offensive thinking | 攻击性思维被放在正面位置，强调以攻击者视角发现薄弱点。 | 白帽思维像压力测试：主动寻找断点，目标是让系统在真实压力下更稳。          |

|                         |                         |                                                |
|-------------------------|-------------------------|------------------------------------------------|
| Real world defense      | 防御要面对真实业务、真实工具链和真实人员协作。 | 理论上可行的控制，在现场环境中还要接受成本、权限、速度和责任分配的检验。           |
| Collective intelligence | 大会主题指向 AI 与白帽的联合智能。     | 读者应关注“人如何指挥 AI”、“AI 如何扩大人类测试半径”、“证据如何沉淀为组织能力”。 |

## 1.2 本讲义的阅读边界

主题 01 的职责是建立入口。它只解释大会为什么把 AI 安全放在主轴、白帽角色发生了什么变化、后续议题怎样排列成路线。以下概念只做导航式点名：

- **Agent/代理、工具调用、MCP**：后续会进入 AI 驱动防御与 MCP 工具主题，这里只把它们看成“模型获得行动能力后带来的新接口”。
- **SAIF、合规、审计链路**：后续会进入治理和证据链主题，这里只提示读者关注控制权、可见性与责任分配。
- **Prompt injection、数据投毒、微调风险**：后续会进入模型输入、训练数据和攻击实验主题，这里只把它们放进风险坐标。
- **CPU 漏洞、签名协议**：后续会进入底层漏洞与协议防御主题，这里只说明 AI 安全仍然依赖传统系统安全的地基。

# 2 会场语境：从会议厅到现场竞技场

## 2.1 地点本身传递的信号

开场字幕给出的叙事很直接：“Welcome to Macau, welcome to MGM Macau and welcome to the land of hackers.” 它把地理地点、会场空间和黑客文化连在一起。对技术会议而言，这种说法承担的功能超过装饰性欢迎词：它在给听众设置心理模型。今天进入的场域包含攻防经验、工具展示、方法争论和现实约束，单向发布会无法容纳这样的密度。

“现场竞技场”这个比喻很准。竞技场里只有漂亮动作不够，动作要经得起对手、规则、计时器和观众检验。对应到 AI 安全：

- **对手** 是攻击者能力与自动化工具；
- **规则** 是业务合规、数据边界、授权范围和披露规范；
- **计时器** 是漏洞响应、补丁窗口、模型迭代速度；

- **观众** 是用户、企业、监管方、合作伙伴和安全社区。

因此，AI 安全的大会语境天然包含现场性。它要求读者把每个后续主题都放回真实约束中观察：技术方案能否复现，证据能否审计，控制能否落地，责任能否说清楚。

## 2.2 大会主题：AI 与白帽的联合智能

主持人口中的年度主题是“Collective Intelligence: The Union of AI and White Hat”。直译为集体智能，关键不在“更多模型”，关键在多种能力的编队：AI 的速度、检索、生成、自动化，与白帽的直觉、怀疑、判断、创造力相互补位。

官方资料中，OpenAI 对智能时代网络安全的判断强调 AI 会同时提升防御自动化与攻击规模化能力，并要求保留部署可见性与控制权。<sup>[OpenAI-Cyber]</sup> Google 在 AI 前沿安全资料中强调 agent 的人类控制者要明确、权力要受限、行动与计划要可观测。<sup>[Google-Frontier]</sup> 这两条合在一起，构成主题 01 的底层判断：AI 安全不能只问“模型强不强”，还要问“谁在控制它”、“它能触达什么”、“行动有没有证据”、“失败后能否回滚”。

### 类比：白帽像飞行测试员

AI 可以像自动驾驶系统一样快速处理传感器、路线和控制建议；白帽更像飞行测试员，负责设计极端场景、识别自动化系统的盲区，并决定什么时候必须人工接管。真正昂贵的错误，通常发生在系统自信但环境已经越界的瞬间。

## 3 白帽角色变化：速度扩大，判断更贵

### 3.1 AI 扩大了安全工作的半径

开场中说 AI 正在改变软件、安全运营、研究流程，甚至改变攻击者思考方式。这个判断要讲得直白一点：AI 让很多原本受人力限制的环节变得廉价，包括扫描、归纳、变体生成、报告初稿、测试样例扩展和日志分析。廉价带来的结果是规模上升，规模上升会把弱控制迅速放大。

可以用一个简化公式表示风险感：

$$R \approx P(T \mid A, E) \times I$$

其中  $R$  是风险， $T$  是威胁事件， $A$  是资产， $E$  是暴露条件， $I$  是影响。AI 的作用经常体现在两个方向：一方面降低攻击者发现路径的成本，使  $P(T \mid A, E)$  上升；另一方面帮助防御方更快发现、验证和修复，使暴露窗口变短。大会把两者放在同一个现场讨论，这一点很现实。

## 3.2 白帽价值从执行转向判断

开场里有一句很重要：AI can scan faster, write faster, and analyze faster, but white hats always ask the question, how? 这里的“how”超过简单操作步骤，它指向因果链条：为什么这个漏洞成立，为什么这个输入会影响模型，为什么这个权限会穿透边界，为什么某个自动化结论看似合理却缺少证据。

白帽在 AI 安全中的价值，正在从“亲手做每一步”转向“定义问题、约束工具、验证证据、判断影响”。执行速度可以由 AI 放大，判断质量仍由人负责。本主题只把 red teaming 放在大会路线图中提示，完整讨论留给后续攻击实验与模型风险主题。

### 现实提醒

把 AI 接进安全流程后，系统会更快地产生结论，也会更快地产生错误结论。快不等于可靠。没有授权边界、日志、复现实验和人工复核的自动化，容易把一次误判扩展成组织级事故。

## 4 议程地图：十个主题如何组成一条路线

### 4.1 从入口到深水区

根据主题切分清单，本场回放被拆成十个独立主题。主题 01 是入口，其余主题可以按四层阅读：

1. **能力层**：AI 驱动防御、AI 模型与工程，回答“AI 能给白帽工作台增加什么能力”。
2. **治理层**：监管合规与 AI 安全运营、全链路审计流程，回答“能力如何进入可控组织流程”。
3. **攻击面层**：MCP 工具、前端签名、微调数据攻击、分布式攻击实验，回答“新接口、新数据和新协作怎样变成风险”。
4. **地基层**：Google CPU 漏洞响应，提醒读者 AI 安全仍压在传统系统安全、硬件、协议和云环境之上。

### 4.2 议程索引表

| 序号 | 主题      | 阅读位置   | 本讲义中的导航含义         |
|----|---------|--------|-------------------|
| 01 | AI 安全世界 | 入口与坐标系 | 建立大会语境、白帽角色和风险地图。 |

|    |                 |      |                           |
|----|-----------------|------|---------------------------|
| 02 | AI 驱动防御         | 能力层  | 从工具到持续化能力，观察 AI 如何放大白帽工作。 |
| 03 | 监管合规与 AI 安全运营   | 治理层  | 把工具、权限、日志、评估和责任放入闭环。      |
| 04 | Google CPU 漏洞响应 | 地基层  | 提醒读者底层漏洞会穿透上层工程假设。        |
| 05 | MCP 工具与代理传播风险   | 攻击面层 | 观察工具描述、上下文和凭证边界的新风险。      |
| 06 | 前端签名防御策略        | 攻击面层 | 从协议约束理解身份、完整性与重放防护。       |
| 07 | 微调数据攻击          | 攻击面层 | 观察训练数据如何改变模型行为边界。         |
| 08 | AI 模型与工程        | 能力层  | 把模型能力放进可交付系统。             |
| 09 | 全链路审计流程         | 治理层  | 给 AI coding 和工具行动留下可追溯证据。 |
| 10 | 分布式攻击实验         | 攻击面层 | 检验单点防御在协作攻击下的假设强度。        |

## 5 风险坐标：读完整场会要盯住什么

### 5.1 五元坐标：资产、威胁、控制、证据、人员

主题 01 可以给后续阅读提供一个轻量坐标系。每听一个技术点，都问五个问题：

- **资产 A**：被保护的对象是什么？模型、数据、凭证、代码、用户会话、业务接口，还是组织声誉？
- **威胁 T**：攻击者想让系统发生什么？泄露、越权、错误执行、拒绝服务、行为偏移，还是证据污染？
- **控制 C**：用什么措施收窄影响面？权限、隔离、速率限制、审批、签名、日志、回滚、人工接管。
- **证据 E**：如何证明问题存在、影响可控、修复有效？截图、日志、diff、测试输出、模型响应、审计记录。
- **人员 H**：谁授权、谁验证、谁响应、谁承担责任？AI 安全最终会落到人类组织结构中。

一个更适合讲义记忆的表达是：



$$\text{AI Security Posture} = f(A, T, C, E, H)$$

这里的  $f$  用作检查表，无需理解成精确数学函数。它提醒读者：模型能力越强，越要把资产、威胁、控制、证据和人员关系说清楚。只有模型输出，没有证据链和责任链，安全判断会悬在空中。

## 5.2 对偶概念：能力与边界

AI 安全最容易被误读的地方，是只谈能力扩展。更完整的读法要成对看：

- **自动化** 对应 **可审计**：自动化越多，越需要记录输入、上下文、工具调用和输出。
- **工具调用** 对应 **最小权限**：模型能调工具，工具就要有作用域、凭证边界和失败保护。
- **生成速度** 对应 **验证深度**：生成越快，抽样复核、回归测试和人工判断越重要。
- **协作智能** 对应 **责任分配**：多角色、多工具、多机构参与时，谁能批准高风险动作必须明确。

SAIF、数据投毒和 prompt injection 等概念会在后续主题中按 contract 展开；在主题 01 中，它们只作为路线提示出现。读者需要先记住一个工程判断：AI 安全是体系化工程，单点技巧不足以承担组织风险。

## 6 如何读后续主题

### 6.1 先看问题类型，再看技术细节

读后续九个主题时，建议先给每个主题贴一个问题类型标签：

- 它讨论的是**能力建设**，还是**攻击面扩张**？
- 它关注的是**单点技术机制**，还是**组织流程闭环**？
- 它的证据来自**实验复现**，还是**运营记录**？
- 它要求的控制是**预防性控制**、**检测性控制**，还是**响应性控制**？

这种读法能避免被名词带着跑。比如 agent、MCP、微调、签名、审计这些词很容易显得互不相关；放回风险坐标后，它们都在回答同一组问题：系统获得新能力后，边界在哪里，证据在哪里，人类如何保持控制。



## 6.2 把白帽问题写成检查清单

开场那句 “white hats always ask the question, how?” 可以进一步拆成检查清单：

1. 这个风险如何进入系统？
2. 它如何跨过边界？
3. 它如何被观测到？
4. 它如何被复现？
5. 它如何被收敛到可修复项？
6. 修复后如何证明风险下降？

这六个问题贯穿整场大会。它们也是从 “听懂一个议题” 走向 “能在组织里处理一个风险” 的桥。

## 7 图像块

下方位置留给 figure agent 的图像块。若 ‘figures.tex’ 已生成，编译时会自动接入；若尚未生成，本文档仍可独立编译。

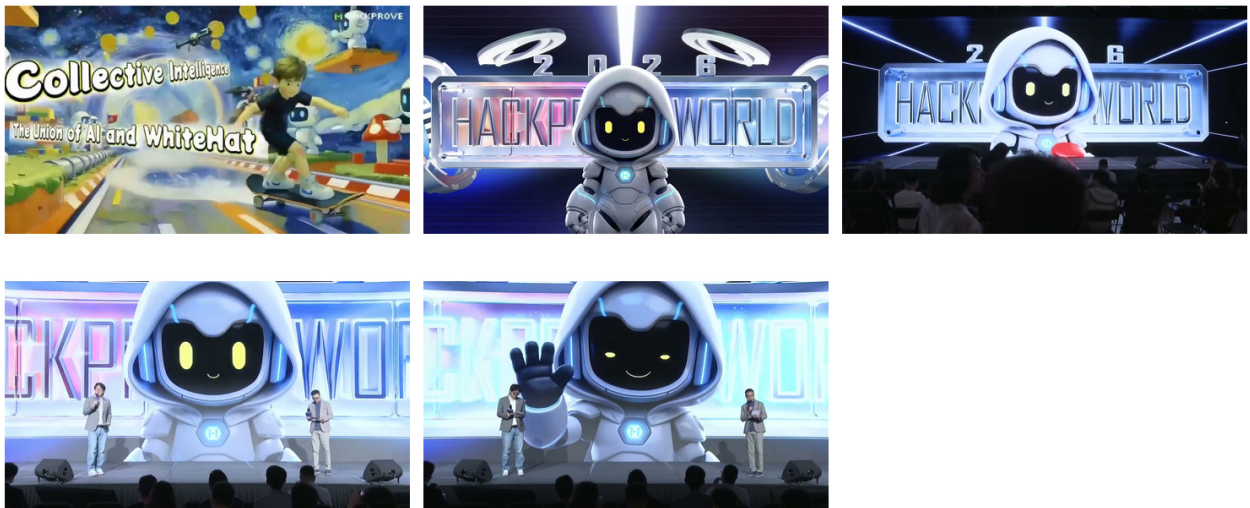


图 1: 主题 01 开场视觉拼图：大会以 “Collective Intelligence” 作为叙事入口，把 AI 与白帽协作放在同一张议程地图中；这张图适合承接后文的攻防、治理与工程主题。<sup>1</sup>



图 2: HackProve World 2026 主视觉：画面强调白帽大会的现场语境，说明本讲义讨论的 AI 安全来自真实会议议程，而非抽象概念列表。<sup>2</sup>



图 3: 大会舞台与主题标识：机器人形象和会场标识共同构成“AI + whitehat”的入口图像，可用于解释白帽角色从单点人工验证扩展到人机协作验证。<sup>3</sup>

## 8 总结

主题 01 给出的核心信息很清楚：HackProve World 2026 把 AI 安全放进白帽大会的主场，强调攻击性思维、真实世界防御和 AI 与白帽的联合智能。AI 会让安全工作更快、更广、更自动化，也会让错误、更大影响面和责任模糊更快出现。白帽的关键价值因此上移到问题定义、边界设定、证据验证和影响判断。

读完整场大会，可以始终拿着一张风险坐标图：资产  $A$ 、威胁  $T$ 、控制  $C$ 、证据  $E$ 、人员  $H$ 。后续每个主题都可以放入这张图。这样读，议程不会散成十个孤立话题，而会形成一条从现场语境到工程治理、从攻击案例到组织能力的路线。

## 官方参考

1. OpenAI, *Cybersecurity in the Intelligence Age*. <https://openai.com/index/cybersecurity-in-the-intelligence-age>
2. Google, *How we're securing the AI frontier*. <https://blog.google/innovation-and-ai/technology/safety-security/ai-security-frontier-strategy-tools/>

引用标识说明：[OpenAI-Cyber] 对应参考 1；[Google-Frontier] 对应参考 2。